

NATIONAL BANK OF ABU DHABI (NABD)

Business Continuity & Disaster Recovery Policy

CLASSIFICATION: HIGHLY CONFIDENTIAL

Document Reference	NABD-POL-BCDR-2025-001
Policy Owner	Chief Risk Officer (CRO)
Policy Custodian	Business Continuity Management Office
Version Number	3.0
Issue Date	October 24, 2025
Effective Date	November 1, 2025
Review Cycle	Bi-Annual (Every 6 Months)
Next Review Date	May 1, 2026
Document Status	APPROVED - ACTIVE

Regulatory Compliance Framework:

UAE Central Bank Regulations | ISO 22301:2019 Business Continuity Management | ISO 27031:2011 ICT Readiness for Business Continuity | Basel III Operational Resilience | NESAs (National Electronic Security Authority) Standards

TABLE OF CONTENTS

ARTICLE I: POLICY FRAMEWORK

- Clause 1.1: Policy Preamble and Strategic Intent
- Clause 1.2: Regulatory and Governance Context
- Clause 1.3: Policy Objectives and Success Criteria
- Clause 1.4: Scope of Application and Boundaries

ARTICLE II: GOVERNANCE STRUCTURE

- Clause 2.1: Business Continuity Governance Model
- Clause 2.2: Organizational Roles and Accountabilities
- Clause 2.3: Committee Structure and Decision Rights
- Clause 2.4: Escalation Protocols and Communication Channels

ARTICLE III: BUSINESS IMPACT ANALYSIS

- Clause 3.1: BIA Methodology and Framework
- Clause 3.2: Critical Business Functions Identification
- Clause 3.3: Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)
- Clause 3.4: Dependency Mapping and Impact Assessment

ARTICLE IV: RISK ASSESSMENT AND THREAT SCENARIOS

- Clause 4.1: Risk Identification and Classification
- Clause 4.2: Threat Scenario Development
- Clause 4.3: Vulnerability Assessment
- Clause 4.4: Risk Treatment and Mitigation Strategies

ARTICLE V: BUSINESS CONTINUITY STRATEGIES

- Clause 5.1: Continuity Strategy Framework
- Clause 5.2: Alternate Site and Workspace Arrangements
- Clause 5.3: Technology Recovery Strategies
- Clause 5.4: People and Process Continuity

ARTICLE VI: DISASTER RECOVERY PLANNING

- Clause 6.1: DR Planning Principles and Architecture
- Clause 6.2: Data Center Recovery Procedures
- Clause 6.3: Application Recovery Sequences
- Clause 6.4: Network and Infrastructure Recovery

ARTICLE VII: INCIDENT RESPONSE AND ACTIVATION

- Clause 7.1: Incident Classification and Severity Levels
- Clause 7.2: Plan Activation Criteria and Authority
- Clause 7.3: Emergency Response Procedures

Clause 7.4: Crisis Communication Protocols

ARTICLE VIII: TESTING, TRAINING AND EXERCISES

Clause 8.1: Testing Strategy and Annual Calendar

Clause 8.2: Exercise Types and Methodologies

Clause 8.3: Training and Awareness Programs

Clause 8.4: Test Results and Continuous Improvement

ARTICLE IX: THIRD-PARTY AND VENDOR RESILIENCE

Clause 9.1: Critical Vendor Identification

Clause 9.2: Vendor BC/DR Requirements

Clause 9.3: Vendor Testing and Validation

Clause 9.4: Vendor Incident Management

ARTICLE X: COMPLIANCE, AUDIT AND ASSURANCE

Clause 10.1: Regulatory Compliance Obligations

Clause 10.2: Internal Audit and Review

Clause 10.3: External Assurance and Certification

Clause 10.4: Non-Compliance and Remediation

SCHEDULE A: Definitions and Terminology

SCHEDULE B: Critical Business Functions Matrix

SCHEDULE C: RTO/RPO Standards by Business Line

SCHEDULE D: Incident Severity Classification

SCHEDULE E: Document Revision History

ARTICLE I: POLICY FRAMEWORK

Clause 1.1: Policy Preamble and Strategic Intent

This Business Continuity and Disaster Recovery Policy (hereinafter referred to as 'the Policy') establishes the comprehensive framework for ensuring operational resilience and continuity of critical business operations at National Bank of Abu Dhabi (NABD) in the event of disruptions, disasters, or crisis situations. The Policy reflects NABD's unwavering commitment to safeguarding stakeholder interests, maintaining financial stability, and upholding regulatory obligations under all circumstances.

Strategic Intent:

- To ensure uninterrupted delivery of critical banking services to customers, regulators, and stakeholders
- To protect the Bank's reputation, brand value, and market position during adverse events
- To minimize financial losses, operational disruptions, and regulatory penalties
- To demonstrate operational resilience in compliance with UAE Central Bank requirements
- To maintain customer confidence and trust through proven recovery capabilities
- To protect employee safety and wellbeing during crisis situations
- To ensure rapid recovery and restoration of normal business operations

Clause 1.2: Regulatory and Governance Context

This Policy is formulated in accordance with and derives its authority from the following regulatory and governance frameworks:

Regulatory Authority	Applicable Regulation/Standard	Key Requirements
UAE Central Bank	Operational Risk Management Regulation	BC/DR plans, testing, governance
UAE Central Bank	Business Continuity Management Standards	RTO/RPO, alternate sites, annual testing
NESA	National Electronic Security Authority Standards	Cybersecurity resilience, incident response
ISO	ISO 22301:2019 - Business Continuity Management	BCMS framework, BIA, testing
ISO	ISO 27031:2011 - ICT Readiness for BC	IT disaster recovery, data protection
Basel Committee	Basel III - Operational Resilience	Operational risk management, resilience

Clause 1.3: Policy Objectives and Success Criteria

Primary Objectives:

Objective Category	Specific Objectives	Success Metrics
Operational Continuity	• Maintain critical operations during disruptions • Achieve defined RTO/RPO targets • Minimize service degradation	• 99.9% achievement of RTO targets • Zero critical service failures • <2% customer complaint rate
Financial Protection	• Limit financial losses from disruptions • Protect revenue streams • Maintain liquidity	• <5% revenue impact during incidents • Zero regulatory fines • Maintain capital adequacy ratios
Regulatory Compliance	• Meet all UAE Central Bank requirements • Achieve ISO 22301 certification • Pass regulatory audits	• 100% compliance with regulations • ISO 22301 certification maintained • Zero audit findings
Stakeholder Protection	• Ensure customer service continuity • Protect employee safety • Maintain investor confidence	• <1% customer attrition • Zero employee safety incidents • Stable credit ratings

Clause 1.4: Scope of Application and Boundaries

1.4.1 Entities and Operations Covered:

This Policy applies comprehensively to all entities, operations, and activities of NABD including:

- All branches, offices, and operational facilities within the United Arab Emirates
- Head Office and corporate functions (Finance, Risk, Compliance, HR, IT, Operations)
- Retail Banking, Corporate Banking, Treasury, and Investment Banking divisions
- Technology infrastructure including data centers, networks, applications, and cloud services
- Critical third-party service providers and outsourced operations
- International branches and representative offices (where applicable)
- Subsidiaries and affiliated entities as designated by the Board

1.4.2 Exclusions and Limitations:

- Customer-facing digital banking platforms (covered under separate Cyber Resilience Policy)
- Physical security and premises protection (covered under Physical Security Policy)
- Fraud prevention and anti-money laundering (covered under Financial Crime Policy)
- Market risk and credit risk management (covered under Risk Management Framework)

ARTICLE II: GOVERNANCE STRUCTURE

Clause 2.1: Business Continuity Governance Model

NABD adopts a three-tier governance model for Business Continuity and Disaster Recovery management, ensuring clear accountability, effective oversight, and rapid decision-making during crisis situations.

Governance Tier	Body/Role	Key Responsibilities
TIER 1: Strategic Oversight	Board Risk Committee	• Policy approval and oversight • Strategic direction • Major incident escalation • Annual BC/DR review
TIER 2: Executive Management	Business Continuity Steering Committee (BCSC)	• Policy implementation oversight • Resource allocation • Crisis management decisions • Quarterly performance review
TIER 3: Operational Execution	Business Continuity Management Office (BCMO)	• Day-to-day BC/DR operations • Plan development and maintenance • Testing coordination • Incident response coordination

Clause 2.2: Organizational Roles and Accountabilities

The following roles and accountabilities are established for effective BC/DR management:

Role	Accountability Level	Key Duties
Chief Risk Officer (CRO)	ACCOUNTABLE	• Overall policy ownership • Board reporting • Regulatory liaison • Budget approval
Head of BCMO	RESPONSIBLE	• Policy implementation • Program management • Testing oversight • Incident coordination
Business Unit Heads	ACCOUNTABLE (for their units)	• BCP development for their units • Resource provision • Testing participation • Recovery execution
Chief Information Officer	ACCOUNTABLE (for IT DR)	• IT disaster recovery • Technology resilience • Data center operations • Cyber incident response
Crisis Management Team	RESPONSIBLE (during incidents)	• Incident assessment • Plan activation • Recovery coordination • Stakeholder communication

All Employees	RESPONSIBLE (individual)	• Policy awareness • Training participation • Procedure compliance • Incident reporting
---------------	--------------------------	---

Clause 2.3: Committee Structure and Decision Rights

2.3.1 Business Continuity Steering Committee (BCSC):

- **Composition:** CRO (Chair), CIO, CFO, Head of Operations, Head of HR, Head of BCMO (Secretary)
- **Meeting Frequency:** Quarterly (minimum), Ad-hoc during major incidents
- **Quorum:** Minimum 4 members including CRO or designated alternate
- **Decision Rights:** Policy amendments, budget allocation, plan activation, vendor selection
- **Reporting Line:** Board Risk Committee (quarterly reports)

2.3.2 Crisis Management Team (CMT):

- **Composition:** CEO/Deputy CEO (Chair), CRO, CIO, Head of Communications, Head of BCMO, Legal Counsel
- **Activation:** Triggered by Severity Level 1 or 2 incidents (see Article VII)
- **Authority:** Full authority to activate recovery plans, allocate resources, make operational decisions
- **Communication:** Hourly updates during active incidents, stakeholder briefings
- **Documentation:** All decisions logged in Crisis Management Log

Clause 2.4: Escalation Protocols and Communication Channels

Escalation protocols ensure timely notification and decision-making during incidents:

Incident Severity	Initial Notification	Escalation Timeline	Final Authority
Level 4 (Minor)	BCMO	Within 4 hours to Business Unit Head	Business Unit Head
Level 3 (Moderate)	BCMO + Business Unit Head	Within 2 hours to CRO	CRO
Level 2 (Major)	BCMO + CRO + CIO	Within 1 hour to CMT	Crisis Management Team
Level 1 (Critical)	Immediate CMT activation	Within 30 minutes to CEO + Board	CEO + Board Risk Committee

ARTICLE III: BUSINESS IMPACT ANALYSIS

Clause 3.1: BIA Methodology and Framework

Business Impact Analysis (BIA) is conducted annually to identify critical business functions, assess potential impacts of disruptions, and establish recovery priorities. The BIA follows a structured six-phase methodology:

- **Phase 1: Scoping and Planning** - Define BIA scope, identify stakeholders, establish timeline
- **Phase 2: Data Collection** - Conduct interviews, distribute questionnaires, gather documentation
- **Phase 3: Impact Assessment** - Analyze financial, operational, regulatory, and reputational impacts
- **Phase 4: Dependency Mapping** - Identify critical dependencies (people, technology, vendors, facilities)
- **Phase 5: RTO/RPO Determination** - Establish recovery time and data loss tolerance objectives
- **Phase 6: Reporting and Validation** - Document findings, validate with business units, obtain approvals

Clause 3.2: Critical Business Functions Identification

Critical Business Functions (CBFs) are activities essential to NABD's operations, regulatory compliance, and stakeholder obligations. CBFs are classified into three tiers based on criticality:

Tier	Criticality	Examples	Max Downtime
Tier 1	Mission Critical	• Payment processing (SWIFT, RTGS) • ATM/POS networks • Core banking system • Treasury operations	≤ 4 hours
Tier 2	Business Critical	• Customer onboarding • Loan origination • Trade finance • Regulatory reporting	≤ 24 hours
Tier 3	Important	• Marketing campaigns • Training programs • Non-critical reporting • Administrative functions	≤ 72 hours

Clause 3.3: Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)

RTO and RPO standards are established based on business criticality, regulatory requirements, and risk tolerance. These objectives drive technology architecture, backup strategies, and recovery procedures.

Business Function	Tier	RTO	RPO	Recovery Strategy
Payment Systems (SWIFT/RTGS)	1	2 hours	0 (zero data loss)	Active-Active data centers
Core Banking System	1	4 hours	15 minutes	Hot standby + real-time replication

ATM/POS Network	1	4 hours	30 minutes	Redundant processing centers
Internet/Mobile Banking	1	4 hours	1 hour	Cloud-based DR with auto-failover
Customer Relationship Mgmt	2	24 hours	4 hours	Warm standby + daily backups
Loan Origination System	2	24 hours	8 hours	Backup data center recovery
HR/Payroll Systems	3	72 hours	24 hours	Tape backup + manual recovery

Clause 3.4: Dependency Mapping and Impact Assessment

Each critical business function is analyzed for dependencies across four categories:

- **People Dependencies:** Key personnel, specialized skills, minimum staffing levels, succession planning
- **Technology Dependencies:** Applications, databases, networks, hardware, cloud services, cybersecurity
- **Facility Dependencies:** Office space, data centers, alternate sites, utilities, telecommunications
- **Vendor Dependencies:** Critical suppliers, service providers, payment processors, cloud vendors

Impact Assessment Criteria:

- **Financial Impact:** Revenue loss, penalty costs, recovery expenses, market value impact
- **Operational Impact:** Service disruption, transaction delays, customer complaints, SLA breaches
- **Regulatory Impact:** Compliance violations, reporting failures, regulatory sanctions, license risk
- **Reputational Impact:** Brand damage, customer attrition, media coverage, stakeholder confidence

ARTICLE IV: RISK ASSESSMENT AND THREAT SCENARIOS

Clause 4.1: Risk Identification and Classification

BC/DR risks are identified through systematic assessment of internal and external threats. Risks are classified into six primary categories:

- **Natural Disasters:** Earthquakes, floods, sandstorms, extreme weather events
- **Technology Failures:** Hardware failures, software bugs, network outages, data corruption
- **Cyber Incidents:** Ransomware, DDoS attacks, data breaches, malware infections
- **Human Factors:** Key person loss, labor strikes, human error, insider threats
- **Infrastructure Failures:** Power outages, telecommunications failures, facility damage
- **External Events:** Pandemics, civil unrest, terrorism, geopolitical events

Clause 4.2: Threat Scenario Development

Threat scenarios are developed to test recovery capabilities and validate continuity strategies. The following scenarios are maintained and tested annually:

Scenario ID	Threat Scenario	Likelihood	Impact	Test Frequency
TS-01	Primary data center complete failure	Low	Critical	Annual
TS-02	Ransomware attack on core banking	Medium	Critical	Bi-annual
TS-03	Pandemic affecting 40% of workforce	Medium	High	Annual
TS-04	Prolonged power outage (>24 hours)	Medium	High	Annual
TS-05	Critical vendor service disruption	Medium	Medium	Bi-annual
TS-06	Telecommunications network failure	Low	High	Annual
TS-07	Head office building evacuation	Low	Medium	Bi-annual

Clause 4.3: Vulnerability Assessment

Vulnerability assessments are conducted quarterly to identify weaknesses in BC/DR capabilities:

- Single points of failure in critical systems and infrastructure
- Gaps in backup and recovery procedures
- Insufficient alternate site capacity or capabilities
- Outdated or untested recovery plans
- Inadequate staff training or awareness
- Vendor concentration risks and dependencies
- Technology obsolescence and end-of-life systems

Clause 4.4: Risk Treatment and Mitigation Strategies

Risk treatment strategies are implemented based on risk assessment results:

Risk Treatment	Strategy	Examples
AVOID	Eliminate the risk by discontinuing the activity	• Decommission legacy systems • Exit high-risk markets • Terminate risky vendor relationships
REDUCE	Implement controls to minimize likelihood	• Redundant systems • Geographic diversification • Enhanced monitoring • Staff cross-training
TRANSFER	Shift risk to third parties	• Insurance coverage • Outsourcing to resilient vendors • Cloud service providers • Contractual risk transfer
ACCEPT	Acknowledge and monitor the risk	• Low-impact, low-likelihood risks • Residual risks after mitigation • Risks below risk appetite threshold

ARTICLE V: BUSINESS CONTINUITY STRATEGIES

Clause 5.1: Continuity Strategy Framework

NABD employs a multi-layered continuity strategy framework designed to ensure resilience across all critical dimensions of operations:

- **Layer 1 - Prevention:** Proactive measures to prevent disruptions (redundancy, maintenance, monitoring)
- **Layer 2 - Preparedness:** Plans, procedures, training, and resources ready for activation
- **Layer 3 - Response:** Immediate actions to contain incidents and protect critical operations
- **Layer 4 - Recovery:** Restoration of normal operations within defined RTO/RPO objectives
- **Layer 5 - Resumption:** Return to full operational capacity and service levels

Clause 5.2: Alternate Site and Workspace Arrangements

NABD maintains geographically dispersed alternate sites to ensure continuity of operations:

Site Type	Location	Capacity	Readiness	Supported Functions
Primary Data Center	Abu Dhabi	100%	Active	All production systems
Secondary Data Center	Dubai	100%	Hot Standby	All critical systems (Tier 1)
Disaster Recovery Site	Sharjah	60%	Warm Standby	Core banking, payments
Business Recovery Center	Abu Dhabi (alternate)	300 seats	Cold Standby	Critical business functions
Work-from-Home	Distributed	Unlimited	Active	All office-based functions

Alternate Site Requirements:

- Minimum 50 km geographic separation from primary site
- Independent power supply with UPS and generator backup
- Redundant telecommunications and internet connectivity
- Physical security controls equivalent to primary site
- Environmental controls (HVAC, fire suppression)
- Quarterly readiness testing and validation

Clause 5.3: Technology Recovery Strategies

Technology recovery strategies are aligned with RTO/RPO requirements:

Technology Component	Recovery Strategy	Implementation
Core Banking System	Active-Active with auto-failover	Real-time synchronous replication between Abu Dhabi and Dubai data centers
Payment Systems (SWIFT)	Hot standby with manual failover	Standby system ready in <2 hours, zero data loss
Customer Databases	Continuous data replication	Database mirroring with 15-minute RPO
Email and Collaboration	Cloud-based with geo-redundancy	Microsoft 365 with multi-region deployment

Network Infrastructure	Redundant paths and carriers	Dual ISPs, MPLS backup, SD-WAN
Backup Systems	Tiered backup strategy	Hourly incremental, daily full, weekly offsite

Clause 5.4: People and Process Continuity

5.4.1 Workforce Continuity Strategies:

- **Cross-Training:** Minimum 2 staff members trained for each critical role
- **Succession Planning:** Documented succession plans for all key positions
- **Remote Work Capability:** 100% of office staff equipped for work-from-home
- **Flexible Staffing:** Agreements with temp agencies for surge capacity
- **Employee Safety:** Evacuation procedures, emergency contacts, welfare checks

5.4.2 Process Continuity Measures:

- Manual workarounds documented for critical automated processes
- Paper-based backup procedures for essential transactions
- Simplified approval workflows during crisis situations
- Pre-authorized emergency spending limits
- Regulatory reporting contingency procedures

ARTICLE VI: DISASTER RECOVERY PLANNING

Clause 6.1: DR Planning Principles and Architecture

Disaster Recovery planning follows a tiered architecture approach with clearly defined recovery sequences, dependencies, and validation checkpoints. All DR plans are maintained in both electronic and hardcopy formats with offline access capability.

- **Principle 1:** Recovery sequences prioritize Tier 1 critical systems first
- **Principle 2:** All recovery procedures tested at least annually
- **Principle 3:** DR plans accessible offline (printed runbooks at alternate sites)
- **Principle 4:** Automated recovery where possible, manual procedures documented
- **Principle 5:** Recovery validation checkpoints at each major milestone

Clause 6.2: Data Center Recovery Procedures

Data center recovery follows a phased approach with defined recovery sequences:

Phase	Activities	Duration	Success Criteria
Phase 1: Assessment	• Damage assessment • Safety verification • Decision to activate DR	0-2 hours	Go/No-go decision made
Phase 2: Infrastructure	• Power systems online • Network connectivity • Storage systems ready	2-4 hours	Infrastructure operational
Phase 3: Core Systems	• Core banking recovery • Payment systems • Customer databases	4-8 hours	Tier 1 systems operational
Phase 4: Business Systems	• CRM, loan systems • Reporting platforms • Support applications	8-24 hours	Tier 2 systems operational
Phase 5: Validation	• End-to-end testing • User acceptance • Performance verification	24-48 hours	Full operations restored

Clause 6.3: Application Recovery Sequences

Applications are recovered in priority order based on business criticality and dependencies. Recovery sequences are documented in detailed runbooks maintained by application owners.

Clause 6.4: Network and Infrastructure Recovery

Network recovery procedures ensure connectivity is restored in the following sequence: (1) Core network infrastructure, (2) WAN connectivity, (3) Branch connectivity, (4) Internet/DMZ, (5) Wireless networks. All network changes during recovery are logged and validated.

ARTICLE VII: INCIDENT RESPONSE AND ACTIVATION

Clause 7.1: Incident Classification and Severity Levels

All incidents are classified into four severity levels based on impact and scope:

Level	Classification	Impact	Examples	Response Time
1	CRITICAL	Bank-wide disruption, major financial and reputational impact	• Cyber attack on core systems • Pandemic	< 30 minutes
2	MAJOR	Multiple business units affected, significant regional impact	• Regional power outage • Critical vendor failure • Major system outage	< 1 hour
3	MODERATE	Single business unit affected, moderate impact	• Data center system failure • Branch closure • Network degradation	< 2 hours
4	MINOR	Limited scope, minimal business impact	• Individual system issue • Single user problem • Minor delay	< 4 hours

Clause 7.2: Plan Activation Criteria and Authority

BC/DR plans are activated when predefined criteria are met. Activation authority varies by severity:

- **Level 1 (Critical):** CEO or CRO authorization required, immediate CMT activation
- **Level 2 (Major):** CRO or CIO authorization, CMT convened within 1 hour
- **Level 3 (Moderate):** Head of BCMO authorization, business unit response
- **Level 4 (Minor):** Business unit head authorization, standard incident response

Clause 7.3: Emergency Response Procedures

Emergency response follows a structured 5-step process: (1) Detection and Reporting, (2) Assessment and Classification, (3) Notification and Escalation, (4) Response and Containment, (5) Recovery and Restoration. All steps are documented in the Emergency Response Playbook.

Clause 7.4: Crisis Communication Protocols

Crisis communication ensures timely, accurate information flow to all stakeholders:

- **Internal Communication:** Email, SMS, emergency hotline, intranet updates (every 2 hours during active incidents)
- **Customer Communication:** Website updates, mobile app notifications, branch signage, call center scripts
- **Regulatory Communication:** UAE Central Bank notification within 4 hours for Level 1/2 incidents

- **Media Communication:** Approved spokespersons only, coordinated through Corporate Communications
- **Vendor Communication:** Critical vendor notification, status updates, recovery coordination

ARTICLE VIII: TESTING, TRAINING AND EXERCISES

Clause 8.1: Testing Strategy and Annual Calendar

A comprehensive testing program validates BC/DR capabilities and identifies improvement opportunities. Testing is conducted according to an annual calendar approved by the BCSC.

Test Type	Frequency	Scope	Participants
Desktop Exercise	Quarterly	Scenario walkthrough, plan review	BCMO, Business Unit Heads
Functional Test	Bi-annual	Individual system/process recovery	IT teams, Application owners
Full DR Test	Annual	Complete data center failover	All IT teams, Critical business users
Business Unit BCP Test	Annual	Department-level continuity	Business unit staff, BCMO
Crisis Management Exercise	Annual	CMT activation and decision-making	CMT members, Senior management
Vendor Recovery Test	Annual	Critical vendor failover	Vendor teams, NABD coordinators

Clause 8.2: Exercise Types and Methodologies

Testing methodologies range from low-impact reviews to full operational tests:

- **Tabletop Exercise:** Discussion-based review of plans and procedures without actual recovery
- **Walkthrough:** Step-by-step review of recovery procedures with key personnel
- **Simulation:** Simulated incident with real-time decision-making (no actual failover)
- **Parallel Test:** Recovery systems activated alongside production (no disruption)
- **Full Interruption Test:** Complete failover to DR site with production shutdown (planned)

Clause 8.3: Training and Awareness Programs

BC/DR training is mandatory for all employees with role-specific requirements:

- **All Employees:** Annual BC/DR awareness training (online module, 30 minutes)
- **Business Unit Staff:** Department-specific BCP training (annual, 2 hours)
- **IT Recovery Teams:** Technical DR procedures training (quarterly, 4 hours)
- **Crisis Management Team:** Crisis leadership and decision-making (bi-annual, full day)
- **BCMO Staff:** BC/DR professional certifications (ISO 22301, CBCP, MBCI)

Clause 8.4: Test Results and Continuous Improvement

All test results are documented in Test Reports submitted to the BCSC within 2 weeks. Findings are categorized as Critical, High, Medium, or Low priority. Critical and High findings require remediation plans within 30 days. Lessons learned are incorporated into plan updates.

ARTICLE IX: THIRD-PARTY AND VENDOR RESILIENCE

Clause 9.1: Critical Vendor Identification

Critical vendors are identified through dependency analysis and classified based on impact to operations:

Vendor Category	Examples	Criticality	BC/DR Requirements
Payment Processors	SWIFT, card networks, clearing houses	Critical	Mandatory BC/DR plans, annual testing, SLA 99.95%
Cloud Service Providers	AWS, Microsoft Azure, SaaS vendors	Critical	Multi-region deployment, failover capability
Core Banking Vendor	Core banking system provider	Critical	Hot standby support, 24/7 support, <4hr response
Telecommunications	Internet, MPLS, voice providers	High	Redundant circuits, diverse routing, SLA 99.9%
Facilities Management	Data center operations, security	High	Backup generators, redundant systems

Clause 9.2: Vendor BC/DR Requirements

All critical vendors must meet the following BC/DR requirements:

- Documented and tested BC/DR plans provided to NABD annually
- ISO 22301 certification or equivalent BC/DR framework
- Defined RTO/RPO aligned with NABD requirements
- Geographic redundancy for critical services
- Annual BC/DR testing with NABD participation
- Incident notification within 2 hours of service disruption
- Right to audit BC/DR capabilities included in contracts

Clause 9.3: Vendor Testing and Validation

Critical vendors participate in annual joint BC/DR testing. Test scenarios include vendor service disruption, failover to alternate vendor sites, and communication protocol validation. Test results are reviewed and remediation tracked.

Clause 9.4: Vendor Incident Management

Vendor incidents are managed through established escalation procedures. Critical vendor incidents trigger NABD incident response protocols. Vendors must provide hourly status updates during active incidents and post-incident reports within 5 business days.

ARTICLE X: COMPLIANCE, AUDIT AND ASSURANCE

Clause 10.1: Regulatory Compliance Obligations

NABD maintains compliance with all applicable BC/DR regulations and standards:

- **UAE Central Bank:** Annual BC/DR attestation, quarterly testing reports, incident notifications
- **ISO 22301:2019:** Maintain certification through annual surveillance audits
- **NESA Standards:** Cybersecurity resilience requirements, incident reporting
- **Basel III:** Operational resilience framework, risk management
- **Internal Policies:** Risk Management Framework, Information Security Policy

Clause 10.2: Internal Audit and Review

Internal Audit conducts annual BC/DR audits covering:

- Policy compliance and governance effectiveness
- BIA accuracy and completeness
- Plan adequacy and currency (last update within 12 months)
- Testing program execution and results
- Vendor BC/DR compliance
- Training and awareness completion rates
- Incident response effectiveness

Clause 10.3: External Assurance and Certification

NABD maintains ISO 22301:2019 certification through annual external audits. Critical vendors must provide SOC 2 Type II reports or equivalent assurance annually. External audit findings are tracked in the Audit Management System with defined remediation timelines.

Clause 10.4: Non-Compliance and Remediation

Non-compliance with this Policy may result in:

- Regulatory sanctions and penalties from UAE Central Bank
- Increased operational risk exposure and potential losses
- Reputational damage and loss of customer confidence
- Disciplinary action for responsible individuals
- Mandatory remediation plans with executive oversight

Remediation Process: All findings categorized by severity (Critical/High/Medium/Low). Critical findings require immediate action plans within 48 hours. High findings remediated within 30 days. Progress tracked monthly by BCSC.

SCHEDULE A: DEFINITIONS AND TERMINOLOGY

Term	Definition
Business Continuity (BC)	Capability to continue delivery of products or services at acceptable predefined levels following
Business Continuity Plan (BCP)	Documented procedures that guide organizations to respond, recover, resume, and restore to
Business Impact Analysis (BIA)	Process of analyzing activities and the effect that a business disruption might have upon them
Crisis Management Team (CMT)	Group of individuals responsible for managing the strategic response to a crisis situation.
Disaster Recovery (DR)	Process of restoring IT systems, data, and infrastructure following a disaster or disruption.
Maximum Tolerable Period of Disruption (MTPD)	Time (MTPD) which the viability of the organization would be threatened if product or service deli
Recovery Point Objective (RPO)	Point to which information used by an activity must be restored to enable the activity to operat
Recovery Time Objective (RTO)	Period of time following an incident within which a product or service must be resumed, or act
Resilience	Ability of an organization to absorb and adapt in a changing environment to enable it to delive

SCHEDULE E: DOCUMENT REVISION HISTORY

Version	Date	Author	Changes Summary	Approved By
1.0	Jan 15, 2023	BCMO	Initial policy creation	Board Risk Committee
2.0	Jul 20, 2024	BCMO	Major revision: Updated RTO/RPO standards, added Board Risk Committee enhanced vendor	Board Risk Committee
3.0	Oct 24, 2025	BCMO	Comprehensive update: ISO 22301:2019 alignment, Board Risk Committee enhanced t	Board Risk Committee

POLICY APPROVAL AND AUTHORIZATION

Role	Name	Signature	Date
Policy Owner (CRO)	Ahmed Al Mansoori	[Signed]	October 24, 2025
Policy Custodian (Head of BCMO)	Patima Al Hashimi	[Signed]	October 24, 2025
Chief Information Officer	Mohammed Al Zaabi	[Signed]	October 24, 2025
Board Risk Committee Chair	Dr. Khalid Al Suwaidi	[Signed]	October 24, 2025

This document is the property of National Bank of Abu Dhabi (NABD) and contains confidential information. Unauthorized distribution, copying, or disclosure is strictly prohibited. This policy is subject to periodic review and may be amended as required to maintain compliance with regulatory requirements and industry best practices.